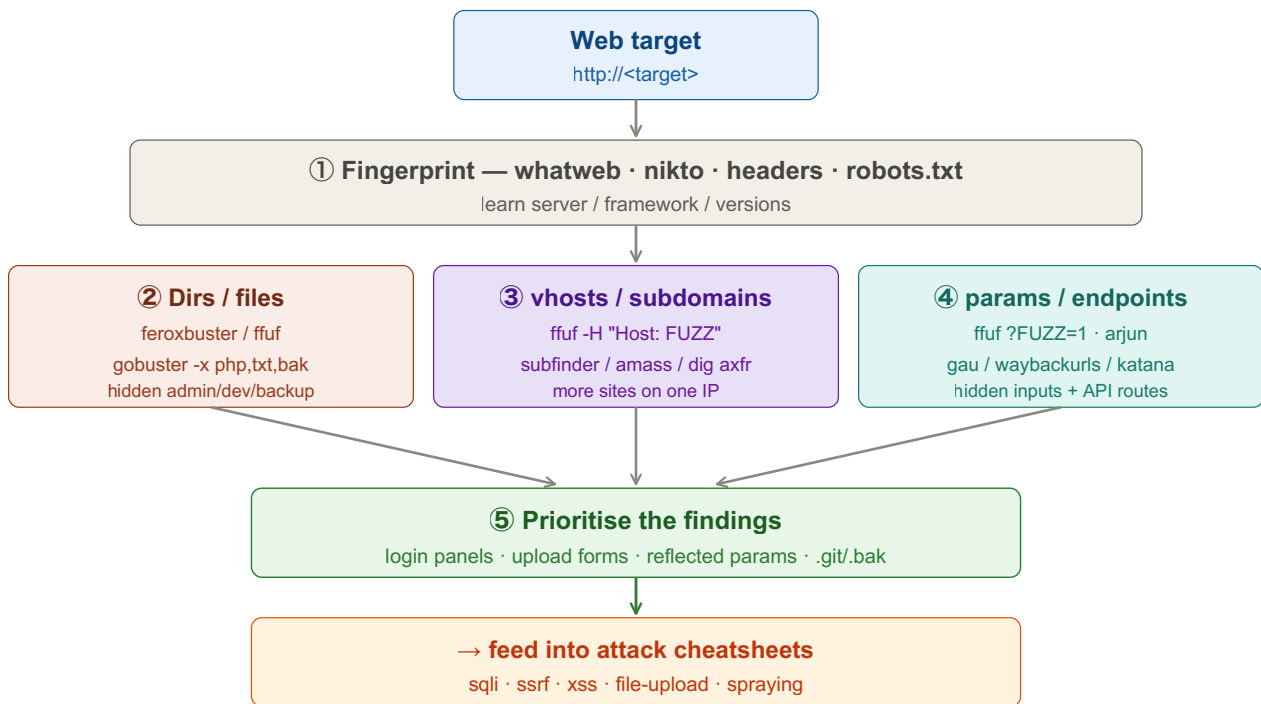


Web Enumeration

Map a web target before attacking: fingerprint the stack, brute-force hidden dirs/files, discover vhosts + subdomains, and pull parameters. Goal = expand the attack surface. Replace <placeholders> with your own values.



① Fingerprint the Stack

Tab 1 · Kali

```
whatweb http://<target>
nikto -h http://<target>
curl -sI http://<target>          # Server, X-Powered-By, cookies
```

Always read /robots.txt, /sitemap.xml, page source, and JS files — they leak hidden paths and API routes.

② Directory & File Brute Force

Tab 2 · Fuzz

```
# feroxbuster — recursive, fast (recommended)
feroxbuster -u http://<target> \
  -w /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt \
  -x php,txt,html,bak -t 50

# ffuf — FUZZ marks the injection point
ffuf -u http://<target>/FUZZ \
  -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt \
  -e .php,.txt,.html -mc 200,301,302,403

# gobuster
gobuster dir -u http://<target> -w <wordlist> -x php,txt,html
```

Cut noise in ffuf with -fc 404, -fs <size>, or -fw <words> to filter a boilerplate response.

③ vhost & Subdomain Discovery

Tab 3 · vhost/subdomain

```
# virtual hosts (same IP, different Host header)
ffuf -u http://<target> -H "Host: FUZZ.<domain>" \
  -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt \
  -fs <default-response-size>

# subdomains — passive then active
subfinder -d <domain> -silent
ffuf -u http://FUZZ.<domain> -w <subdomain-wordlist> -mc 200,301,302
dig axfr <domain> @<ns-ip>          # zone transfer if misconfigured
```

Add discovered vhosts to /etc/hosts, then repeat fingerprint + dir-brute on each.

④ Parameter & Endpoint Discovery

Tab 4 · params

```
# hidden params
ffuf -u "http://<target>/page?FUZZ=1" \
    -w /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt -fs <size>
arjun -u http://<target>/page

# harvest URLs/params from archives + crawling
gau <domain> ; waybackurls <domain> ; katana -u http://<target>
```

⑤ Prioritise → Attack

login / admin panel	→ default creds / auth bypass / spraying
upload form	→ file-upload bypass
param reflecting input	→ XSS / SSTI
param hitting backend	→ SQLi / command injection
URL-like param	→ SSRF (see ssrf cheatsheet)
.bak / .git / config	→ source + secrets (try /.git/ dumping)

Key SecLists paths: *raft-*-directories/files*, *directory-list-2.3-medium*, *subdomains-top1million-**, *burp-parameter-names*.

Key idea: web enumeration is attack-surface expansion. The app only links to a fraction of what exists — brute-forcing directories, vhosts, subdomains, and parameters surfaces the forgotten admin panel, the dev endpoint, the backup file, or the unlinked API that becomes your way in. Fingerprint first, fuzz broadly, then drill into whatever looks abnormal.